Security Assessment & Data Protection Review

GDPR ARTICLE 32

VeriPulse B.V.

Date: May 2026

Prepared by: Haitam Laafar

Table of Contents

1. Introduction & Regulatory Context....3
1.1 Purpose of This Assessment....3
1.2 GDPR Application....3
1.3 Special Category Data....3
2. Record of Processing Activities (ROPA)....4
2.1 ROPA Observations....5
3. Article 32 Security Assessment....6
3.1 Assessment Summary....6
3.2 Detailed Findings....7
3.3 The Dual-Framework Breach Scenario....9
4. DPIA Screening....10
4.1 DPIA Scope — When Conducted....11
5. Personal Data Breach Notification Procedure....12
5.1 What Constitutes a Personal Data Breach....12
5.2 Breach Severity Classification....12
5.3 Notification Procedure — Step by Step....13
5.4 Key Contacts....14
6. Conclusion....15

1. Introduction & Regulatory Context

1.1 Purpose of This Assessment

This document presents a GDPR Article 32 security assessment for VeriPulse B.V., a Utrecht-based (fictional) SaaS company processing patient-reported health outcome data on behalf of hospital and pharmaceutical clients. It evaluates the technical and organisational measures protecting personal data against the requirements of the **General Data Protection Regulation (EU) 2016/679.**

This assessment is a companion document to the **VeriPulse NIS2 Gap Analysis (April 2026).** Whereas the NIS2 analysis addressed cybersecurity resilience obligations, this document addresses data protection obligations. The two frameworks share significant overlap, particularly around **incident response, access control, and encryption.**

1.2 GDPR Application

GDPR applies to any organisation that processes personal data of EU residents in the context of its activities, regardless of the organisation's location. VeriPulse meets this threshold on multiple grounds:

- VeriPulse is incorporated and operates in the Netherlands, an EU Member State
- VeriPulse processes patient-reported symptom and outcome data submitted by individuals receiving healthcare from Dutch hospitals
- VeriPulse acts as both a Data Controller (for platform usage data and client account data) and a Data Processor (for patient-reported data processed on behalf of hospital clients)

The distinction between controller and processor roles is important. As a **processor**, VeriPulse is bound by **Article 28** contractual obligations with its hospital clients and carries direct liability for breaches of its processing obligations. As a **controller**, VeriPulse is independently accountable to the Autoriteit Persoonsgegevens (AP), the Dutch supervisory authority, for its own data processing activities.

1.3 Special Category Data

Patient-reported health data falls under GDPR **Article 9** as special category data: the **highest** sensitivity classification under the regulation. Processing special category data is prohibited by default under **Article 9(1)** and is only permitted under one of the explicit exceptions in **Article 9(2).**

For VeriPulse, the applicable legal basis for processing health data is **Article 9(2)(h):**

➔ *processing necessary for the purposes of preventive or occupational medicine, medical diagnosis, or the provision of health or social care*.

GDPR Tier	Implication for VeriPulse
Standard personal data (Name, email, account data)	Standard Article 6 legal basis; Normal security requirements
Special category **(Art.9)** (Patient-reported outcomes)	Heightened legal basis required; Stricter security; DPIA likely mandatory; Breach notification obligations amplified

2. Record of Processing Activities (ROPA)

Article 30 of GDPR requires VeriPulse to maintain a written record of all personal data processing activities. This ROPA documents each processing activity, the legal basis on which it relies, the categories of data involved, and the safeguards applied. It serves as the foundation for the Article 32 assessment in Section 3 and the DPIA screening in Section 4.

Activities marked **Processor** reflect activities where VeriPulse acts on behalf of hospital or pharma clients under a **Data Processing Agreement (DPA).**

Activities marked **Controller** reflect activities where VeriPulse determines the purpose and means of processing **independently.**

Activity	Role	Data Subjects	Data Categories	Purpose	Retention	Recipient	Safeguards
Patient reported outcome **(PRO)** data collection **Art.9(2)(h)**	**Processor**	Hospital patients	Health outcomes; symptom severity scores; treatment responses	Enable hospitals and pharma clients to collect and analyse patient-reported outcomes	Per hospital client contracts.	Hospital clients; pharma clients; Azure (hosting)	Azure encryption at rest/transit; Access controls; Pseudonymization
Platform usage and analytics data **Art.6(1)(b)**	**Controller**	VeriPulse platform users	Login events; session data; IP addresses	Platform improvement; Support; Billing	2 years from last activity	Atlassian (support); Azure (hosting);	Azure encryption; access controls
Client account and contact data **Art.6(1)(b)**	**Controller**	Employees of hospital and pharma clients	Name; email; phone;	Account management; invoicing;	Duration of contract + 3 years	Atlassian (support); Slack	Platform standard security
Employee and contractor personal data **Art.6(1)(b)** **Art.6(1)(c)**	**Controller**	VeriPulse staff and contractors	Name; Contact; Salary; Bank details;	Administration; payroll	Duration of employment + 7 years (legal retention obligation)	Payroll provider; legal counsel	HR system access controls
Prospective client and marketing data **Art.6(1)(a)** **Art.6(1)(f)**	**Controller**	Conference Contacts: Website enquiries	Name; Work email; Work phone;	Business development; marketing	3 years from last interaction Or consent withdrawal	CRM tool: email platform	Standard CRM Tool security

2.1 ROPA Observations

We note in this section three distinct observations from the **Record of Processing Activities (ROPA)** that directly inform the security assessment:

- **Observation 1: Data Processing Agreements are unverified**

  VeriPulse acts as a processor for hospital clients' patient data. **GDPR Article 28** requires a written **Data Processing Agreement (DPA)** to be in place with each controller client. During evidence gathering, no **DPAs** were produced for review. Their existence and adequacy cannot be confirmed. This is a standalone compliance gap independent of any technical security control.

- **Observation 2: Sub-processor chain is ungoverned**

  VeriPulse uses Azure, AWS, and Atlassian as sub-processors for special category health data. **Article 28(2)** requires VeriPulse to obtain written authorisation from its hospital controller clients before engaging sub-processors. No evidence of such authorisation exists. This mirrors the supply chain gap identified under **NIS2 Article 21(d)** and represents **dual-framework exposure.**

- **Observation 3: Retention periods are undefined for the most sensitive data**

  Retention periods for patient-reported health data are described as *“as per hospital client contracts”*. No internal retention policy exists at VeriPulse level. If a hospital contract is silent on retention, VeriPulse has no defined period after which health data is deleted which is a direct violation of the GDPR storage limitation principle under **Article 5(1)(e).**

3. Article 32 Security Assessment

Article 32 requires VeriPulse to implement technical and organisational measures appropriate to the risk posed by its processing activities. The standard is an appropriate security level, assessed against the nature, scope, context, and purposes of processing, and the risks to the rights and freedoms of data subjects.

Given that VeriPulse processes special category health data under Article 9, the threshold for “appropriate” measures is significantly higher than for standard personal data processing. The assessment below reflects this elevated standard.

3.1 Assessment Summary

Measures Assessed	🔴 Non-Compliant	🟡 Partially Compliant	🟢 Compliant
9	6	3	0

No Article 32 measure was found to be fully compliant. The most severe finding is the unconfirmed existence of Data Processing Agreements **(Article 28)**. VeriPulse may be processing special category health data as a processor without any legal contractual framework in place. This is a critical compliance failure that exists entirely independently of any technical security gap.

3.2 Detailed Findings

Article	Measure	Current State	Status	Gap	Risk Implication
Art.32 (1)(a)	**Pseudonymization & Encryption**	Azure provides encryption at rest and in transit by default. Patient data is pseudonymised by design. Patient identifiers are held by hospital clients, not VeriPulse. No encryption policy document exists.	🟡 **Partial**	Pseudonymization is implemented but undocumented as a deliberate control. No key management policy. No encryption standard for HL7 FHIR API transport verified. Mirrors NIS2 gap (h).	Re-identification of pseudonymised health data via API interception or insider access. Without documented standards, encryption quality cannot be verified or demonstrated.
Art.32 (1)(b)	**Confidentiality Integrity & Availability**	Azure SLA provides 99.9% availability for hosted services. No internal confidentiality policy. No integrity monitoring on patient data datasets.	🔴 **Non-Compliant**	No confidentiality policy exists. Data integrity is unmonitored. Platform availability targets are undefined at VeriPulse level. No controls verify that data has not been tampered with between collection and delivery to clients.	Undetected data corruption could affect clinical decisions made by hospitals based on VeriPulse-processed data. Confidentiality breach of health data triggers **Art.34** individual notification obligations.
Art.32 (1)(c)	**Resilience of Processing Systems**	Azure provides infrastructure resilience. No application-layer resilience architecture is documented Mirrors NIS2 gap (c).	🔴 **Non-Compliant**	VeriPulse's processing capability has no documented resilience posture beyond cloud-provider defaults. A platform failure would interrupt patient data collection for hospital clients with no defined recovery timeline.	Prolonged processing unavailability affecting hospital clinical workflows. Regulatory scrutiny if unavailability affects the lawful processing of health data under **Art.9(2)(h).**
Art.32 (1)(d)	**Restoration of Availability & Access**	Azure backup capabilities available but unconfigured beyond defaults. No tested recovery process. Mirrors NIS2 gap (c).	🔴 **Non-Compliant**	No tested process exists for restoring access to health data following a destructive incident. Backup coverage and integrity are unverified.	Permanent loss of patient-reported health data in a destructive attack. VeriPulse would be unable to fulfil its processor obligations to hospital clients and could not demonstrate data integrity to regulators post-incident.
Art.32 (2)	**Regular Testing & Evaluation**	No security testing programme exists. No penetration testing, vulnerability scanning, or GDPR-specific control review has been conducted. Mirrors NIS2 gap (f).	🔴 **Non-Compliant**	VeriPulse has no process for evaluating the effectiveness of its Article 32 measures. Controls are untested. Degradation of security configurations protecting health data would go undetected.	Inability to demonstrate to the AP that technical measures are effective. A direct **Art.32** requirement. Control failures affecting health data could persist undetected, increasing breach probability and severity.

Article	Measure	Current State	Status	Gap	Risk Implication
Art.25	**Data Protection by Design & Default**	Pseudonymization was implemented at the platform design stage. No formal Art.25 policy. No data minimisation review has been conducted.	🟡 **Partial**	Pseudonymization demonstrates intent but no systematic privacy-by-design process governs platform development. New features could introduce unnecessary data collection without formal review. Data minimisation against **Art.5(1)(c)** has not been assessed.	Collection of unnecessary personal data creating disproportionate risk. Inability to demonstrate **Art.25** compliance.
Art.28	**Processor Obligations & DPAs**	VeriPulse acts as a processor for hospital clients' health data. No **DPAs** confirmed as existing. Sub-processor agreements with Azure, AWS, and Atlassian not verified.	🔴 **Non-Compliant**	No **DPAs** confirmed. No sub-processor authorisation chain documented. VeriPulse is processing special category health data as a processor without the contractual framework Article 28 requires.	Direct GDPR violation independent of any technical breach. Exposure of hospital clients to regulatory risk through VeriPulse's non-compliance. AP enforcement action possible without any security incident occurring.
Art.5 (1)(e)	**Storage Limitation**	Retention periods for patient health data defined as “per client contract.” No internal retention policy. No automated deletion or archiving process. No retention schedule reviewed against legal basis.	🔴 **Non-Compliant**	VeriPulse has no defined retention period for its most sensitive data category. No deletion process exists. Health data may be retained indefinitely beyond its processing purpose.	Indefinite retention of special category health data with no lawful basis is a direct **Art.5(1)(e)** violation. Increased breach impact if retained data exceeds what is necessary for the processing purpose.
Art.13/ 14	**Transparency & Privacy Notices**	No privacy notice reviewed during this assessment. VeriPulse's website and client onboarding materials were not assessed for Art.13/14 compliance.	🟡 **Partial**	Transparency obligations have not been formally assessed. Assumed partially met via client contracts but individual data subject notice obligations under Art.13 have not been verified.	Data subjects may not be adequately informed of VeriPulse's role in processing their health data. Complaint risk to the AP from data subjects or client hospitals.

3.3 The Dual-Framework Breach Scenario

The following table illustrates how a single security incident at VeriPulse would simultaneously trigger obligations under both GDPR and NIS2, demonstrating why these frameworks must be managed together and not in isolation.

Timeline	NIS2 Obligation (Article 23)	GDPR Obligation (Articles 33 & 34)
T + 24 hours	Early warning to NCSC-N: Incident type, initial scope, any cross-border impact.	Initial assessment: has personal data been breached? If yes or suspected: begin 72h AP notification clock.
T + 72 hours	Detailed incident notification to NCSC-NL: cause assessment, affected systems, containment measures.	Notify Autoriteit Persoonsgegevens (AP): nature of breach, categories and approximate number of data subjects affected, likely consequences, measures taken. Mandatory unless breach is unlikely to result in risk.
T + 72 hours (parallel)	Notify affected clients if service disruption is confirmed.	If breach is likely to result in HIGH risk to data subjects (health data breach almost always qualifies): notify affected individuals directly without undue delay. No fixed deadline but as soon as possible.
T + 30 days	Final report to NCSC-NL: root cause, full impact, remediation, lessons learned.	No fixed 30-day GDPR deadline but AP may request full documentation at any point.

4. DPIA Screening

Article 35 of GDPR requires a Data Protection Impact Assessment (DPIA) where processing is likely to result in a high risk to the rights and freedoms of natural persons. The EDPB and the Autoriteit Persoonsgegevens have published criteria to help organisations determine whether a DPIA is mandatory.

A DPIA is required if processing meets at least two of the nine criteria published by the EDPB. VeriPulse's patient data processing is assessed below.

EDPB DPIA Criterion	Assessment for VeriPulse	Met?
1. Evaluation or scoring (including profiling)	VeriPulse aggregates patient-reported outcomes for analysis by hospitals and pharma clients	✅ Yes
2. Automated decision-making with legal or similarly significant effect	VeriPulse's platform analytics may inform clinical treatment decisions. While not automated decisions in the strict sense, the output significantly affects patient care.	⚠️ Likely
3. Systematic monitoring	Continuous collection of patient symptom data over time constitutes systematic monitoring of health status.	✅ Yes
4. Sensitive data or data of a highly personal nature (Article 9)	Patient-reported health outcome data is unambiguously special category data under Article 9.	✅ Yes
5. Data processed at large scale	VeriPulse processes data for 7 hospitals and 3 pharma companies. The scale is significant but not yet at population level.	⚠️ Borderline
6. Matching or combining datasets	VeriPulse's HL7 FHIR API integrations combine PRO data with hospital EHR data	✅ Yes
7. Data concerning vulnerable data subjects	Hospital patients, particularly those with serious or chronic conditions, are a vulnerable population.	✅ Yes
8. Innovative use of technology	HL7 FHIR API integration with EHR systems in a SaaS context represents a relatively novel technical architecture in Dutch healthcare.	⚠️ Likely
9. Transfer outside EU / processing preventing exercise of rights	Data stored in EU Azure regions only. No international transfers identified.	❌ No

DPIA screening results show that DPIA is **required.** VeriPulse's patient data processing meets at least five of the nine EDPB criteria. A DPIA is mandatory before processing continues.

The absence of a DPIA for processing that clearly requires one is an independent GDPR violation under Article 35. The Autoriteit Persoonsgegevens has issued guidance specifically targeting healthcare data processors and has demonstrated willingness to take enforcement action against organisations that fail to conduct mandatory DPIAs.

4.1 DPIA Scope — When Conducted

When VeriPulse conducts its DPIA, the following areas must be addressed as a minimum:

- **Necessity and proportionality assessment:** is the data collected the minimum required for the processing purpose?
- **Risk assessment:** systematic identification of risks to data subjects from the processing activities documented in the ROPA
- **Technical and organisational measures:** demonstration that Article 32 measures are proportionate to the risks identified
- **Sub-processor review:** assessment of Azure, AWS, and Atlassian as sub-processors handling health data
- **HL7 FHIR integration risk:** specific assessment of risks arising from API connectivity to hospital EHR systems
- **Consultation with the external DPO:** Article 35(2) requires DPO involvement in the DPIA process

The DPIA must be documented, retained, and made available to the AP on request. It should be reviewed whenever VeriPulse makes significant changes to its processing activities.

5. Personal Data Breach Notification Procedure

5.1 What Constitutes a Personal Data Breach

Under GDPR Article 4(12), a personal data breach is a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data transmitted, stored, or otherwise processed.

For VeriPulse this includes, but is not limited to:

- Unauthorised access to patient-reported health data by an internal or external party
- Accidental deletion or corruption of patient data with no recoverable backup
- Ransomware encrypting systems processing patient data, even if no exfiltration is confirmed
- Misconfiguration of Azure storage exposing patient data to unintended parties
- Disclosure of patient data to the wrong hospital or pharmaceutical client
- Loss or theft of a device containing unencrypted personal data

A breach does **NOT** require confirmed exfiltration to trigger notification obligations. Unauthorised access alone, even if brief, constitutes a breach requiring assessment.

5.2 Breach Severity Classification

Level	Classification	Examples	Notification Obligation
L1	High Risk	Health data accessed or exfiltrated; ransomware affecting patient data systems; API credential compromise; large-scale accidental disclosure	**Notify AP within 72**h. Notify affected data subjects without undue delay. Notify hospital/pharma clients immediately. Activate NIS2 Incident Response Plan (**IRP)** in parallel.
L2	Medium Risk	Limited access to non-health personal data; isolated misconfiguration with no confirmed access; single record misdisclosure	Assess within 4h. **Notify AP within 72h** if risk to data subjects cannot be ruled out. Document in breach register regardless.
L3	Low Risk	Encrypted device lost with no access key; accidental email to wrong internal recipient with no sensitive data; minor policy violation	Document in breach register. No AP notification required if risk to individuals is unlikely. DPO must confirm this assessment.

5.3 Notification Procedure — Step by Step

Identify & Contain (T = 0)

1. Any staff member who becomes aware of an actual or suspected personal data breach must immediately notify the IT Manager and the external DPO by phone.
2. The IT Manager takes immediate containment steps to limit ongoing exposure (revoke access, isolate systems, disable affected devices).
3. The external DPO makes an initial assessment of whether a personal data breach has occurred or is suspected.

Assess Risk to Data Subjects (T + 1 to 4h)

4. The DPO, CTO, and IT Manager jointly assess the severity of the breach using the classification table in Section 5.2.
5. Key questions: What data was affected? Whose data? Is it health data (Article 9)? How many individuals? Is there ongoing risk? Is re-identification possible?
6. Document the assessment in the breach register, including the rationale for the severity classification.
7. If the breach involves patient health data, classify it as L1 immediately. Do not wait for confirmation of exfiltration.

AP Notification (Before T + 72h)

8. The CTO, advised by the DPO and legal counsel, notifies the Autoriteit Persoonsgegevens via the AP breach notification portal.
9. The notification must include: nature of the breach; categories and approximate number of data subjects and records affected; name and contact details of the DPO; likely consequences of the breach; measures taken or proposed to address the breach.
10. If full information is not available within 72h, submit what is known and update the AP as additional information becomes available. The 72h deadline applies to the initial notification, not the complete picture.
11. Retain a copy of the submission and the AP's acknowledgement reference number.

Individual Notification (Without Undue Delay — L1 Breaches)

12. For L1 breaches involving health data: notify affected data subjects directly. In VeriPulse's case, direct notification of individual patients may need to be coordinated through the hospital client (the controller) and through appropriate notification channels.
13. Individual notification must describe: the nature of the breach in plain language; the name and contact details of the DPO; the likely consequences; the measures taken; and any steps data subjects should take to protect themselves.
14. Legal counsel must review all individual notification content before sending.

Client Notification

15. Hospital and pharma clients must be notified of any breach affecting data processed on their behalf. Notification timing should be aligned with AP notification, inform clients at the same time or before the AP submission wherever possible.
16. Clients will have their own regulatory obligations triggered by VeriPulse's breach. Providing them with timely, accurate information is both a legal and contractual obligation.

Document & Review

17. All breaches, including those not reported to the AP, must be documented in VeriPulse's Article 33(5) breach register, recording: date detected, date notified (if applicable), nature, data affected, response actions, and rationale for any decision not to notify.
18. The DPO reviews the breach register quarterly and presents a summary to the CTO.
19. Following any L1 breach, a formal post-incident review must be conducted within 30 days, with findings presented to the board and incorporated into the next DPIA review.

5.4 Key Contacts

Role	Contact	Responsibility	When to Engage
External DPO	[Name] — [email] — [phone]	GDPR breach assessment, AP notification, data subject rights	Immediately upon suspected breach
CTO	[Name] — [email] — [phone]	Breach commander, client notification, board escalation	Within 1h of L1/L2 classification
IT Manager	[Name] — [email] — [phone]	Technical containment, evidence preservation, system investigation	Immediately upon detection
Legal Counsel	[Firm] — [phone]	Review all external notifications before sending	Before any AP or individual notification is submitted
Autoriteit Persoonsgegevens	autoriteitpersoonsgegevens.nl	Dutch supervisory authority	Within 72h of breach awareness (L1/L2)

6. Conclusion

Taken together, the NIS2 Gap Analysis and this GDPR assessment reveal an organisation operating in a high-risk regulatory environment with a foundational compliance deficit across both frameworks. The risks do not add together linearly, they multiply. A single security incident at VeriPulse today would trigger:

- NIS2 Article 23 reporting obligations to NCSC-NL (24h / 72h / 30 days)
- GDPR Article 33 notification to the Autoriteit Persoonsgegevens (72h)
- GDPR Article 34 direct notification to affected patients (without undue delay)
- Contractual notification obligations to hospital and pharma clients
- Potential AP enforcement investigation triggered by the absence of a DPIA
- Potential AP enforcement investigation triggered by the absence of DPAs

VeriPulse currently has documented procedures for none of these. The Section 7 NIS2 procedure and the Section 5 GDPR procedure in this document are the starting point but they require board adoption, staff training, and practical testing before they have any real-world value.